

TechCorp AI Safety Guidelines

Responsible AI Principles & Security Requirements

Version: v1.5

Document: TC-AIS-005

TechCorp Internal

1. Responsible AI Principles

TechCorp is committed to deploying AI systems that are safe, fair, transparent, and accountable. All AI-powered products must adhere to the following principles:

Principle	Definition
Fairness	AI systems must not discriminate based on protected characteristics
Transparency	Users must know when they are interacting with an AI system
Accountability	Every AI decision must be traceable to a human-reviewable audit log
Safety	AI outputs must not cause harm to users, third parties, or society
Privacy	Minimum necessary data collection; right to deletion honored
Reliability	AI systems must gracefully handle edge cases and model failures

2. Sensitive Data Handling

- PII (names, emails, SSNs, phone numbers) must be detected and masked before LLM processing
- Use Microsoft Presidio or AWS Comprehend PII detection on all input/output pipelines
- Financial data (card numbers, account numbers) are strictly forbidden from LLM context
- Health data handling requires explicit HIPAA compliance review before deployment
- All sensitive data in prompts must be tokenized — real values replaced with synthetic tokens
- Audit logs of what data was processed by which model are retained for 12 months

3. Prompt Injection Protection

Detection	Rule-based + ML classifier on every user input before injection
Patterns Blocked	'Ignore previous instructions', role-play overrides, jailbreak patterns
Delimiter Isolation	User content always wrapped in XML tags; system prompt structurally separate
Input Validation	Reject inputs > 2,000 tokens or containing suspicious Unicode sequences

Canary Tokens	Hidden tokens in system prompts to detect extraction attempts
Rate Limiting	Aggressive throttling on accounts triggering injection alerts
Incident Threshold	3+ injection attempts from same user triggers account review

4. Data Privacy

- GDPR Article 17 (Right to Erasure): deletion requests fulfilled within 30 days across all systems
 - Data residency: EU customer data never leaves eu-west-1 region
 - Zero-retention mode: opt-in feature prevents any logging of user prompts/responses
 - Third-party LLM providers (Anthropic, OpenAI) configured with zero-data-retention API
 - Annual privacy impact assessments for all AI features processing personal data
 - Privacy by design: new features require DPO sign-off before launch
-

5. Security Requirements

API Auth	All LLM API calls authenticated with rotated keys (90-day rotation)
Key Storage	AWS Secrets Manager — no plaintext keys in code or environment vars
Network	LLM calls via VPC endpoint or private link where available
Output Scanning	All model outputs scanned for malicious content before display
SSRF Prevention	Model cannot trigger outbound HTTP requests to internal networks
Model Versioning	Production models pinned to specific versions — no auto-updates
Vulnerability Mgmt	Quarterly red-team exercises targeting AI attack surfaces

6. Human Review Policy

- High-stakes decisions (contract generation, financial recommendations) require human confirmation
 - All AI-generated content used in external communications must be reviewed before sending
 - Automated review queue: responses flagged by safety classifier go to human reviewer within 2h
 - Customer-facing AI agents must offer 'Talk to a human' option at any point in the conversation
 - Weekly AI output audits: random sample of 200 production responses reviewed by QA team
 - Any model update to a production persona requires 48-hour staged rollout with human monitoring
-

7. Logging Policy

What is Logged	Model ID, prompt hash, output hash, latency, token count, safety flags
What is NOT Logged	Raw user prompt text (unless zero-retention is off), PII, passwords

Retention	90 days for operational logs; 12 months for security audit logs
Access	Logs accessible only to SRE, Security, and AI Safety teams
Encryption	All log streams encrypted with AES-256 at rest
Compliance	Logs exportable in SIEM-compatible format (CEF/LEEF)

8. Incident Reporting

Severity 1	AI output causes user harm or data breach — report within 1 hour
Severity 2	Safety classifier false negative or PII leak — report within 4 hours
Severity 3	Prompt injection attempt (blocked) — report within 24 hours
Report To	ai-safety@techcorp.io + Security team Slack channel #ai-incidents
Post-Mortem	Required for all Sev1/Sev2 incidents within 5 business days
Regulator	GDPR Article 33 breach notification to DPA within 72 hours if PII affected